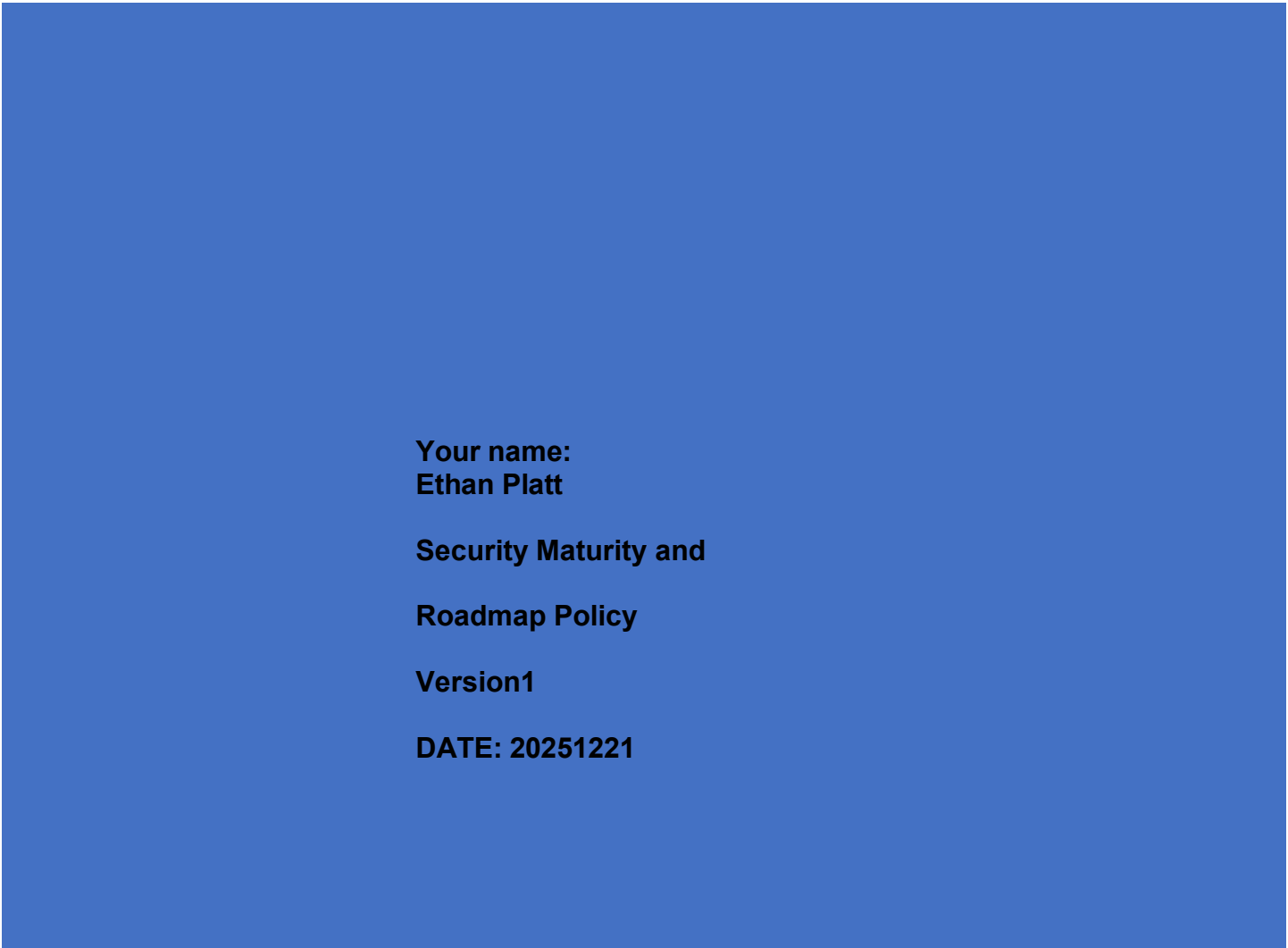




SNOWBE ONLINE

Security Maturity and Roadmap Policy



Your name:
Ethan Platt

Security Maturity and
Roadmap Policy

Version1

DATE: 20251221

Table of Contents

PURPOSE..... 2

SCOPE..... 2

DEFINITIONS..... 2

ROLES & RESPONSIBILITIES 3

POLICY 3

EXCEPTIONS/EXEMPTIONS 3

ENFORCEMENT 4

VERSION HISTORY TABLE 5

CITATIONS 6

Purpose

The purpose of this policy is to establish a structured approach for measuring, reporting, and improving the cybersecurity maturity of SnowBe Online. As the organization continues to grow and prepares for public accountability, security maturity must move beyond ad hoc controls and evolve into a measurable, repeatable, and continuously improving program.

This policy ensures that SnowBe’s cybersecurity practices align with its risk profile, regulatory obligations, and long-term business goals by adopting a formal maturity framework and roadmap.

Scope

This policy applies to:

- SnowBe’s Online information systems, applications, networks, and data
- AWS-hosted systems and on-premise environments
- Employees, contractors and third party service providers
- All cybersecurity domains defined by the cybersecurity maturity model certification (CMMC) framework

Definitions

Term	Definition
Security Maturity	A measure of how well cybersecurity practices are implemented, managed, and improved over time
CMMC (Cybersecurity Maturity Model certification)	A framework used to measure cybersecurity practices across defined maturity levels and security domains.
Maturity Level	A stage that represents how advanced and effective security practices are
Security Domain	A category of security practices (e.g., Access Control, Incident Response).
Security Roadmap	(A multi-year plan that outlines prioritized security improvements.
Risk Appetite	The level of risk an organization is willing to accept
Evidence	Documentation or technical proof used to validate maturity scores.

Roles & Responsibilities:

Role	Responsibilities
CISO	Owns the policy, oversees annual CMMC-based maturity assessments
IT team	Implement security controls and improvements defined in the roadmap
System Owners	Participate in risk and maturity discussions

Policy

SnowBe Online will adopt the Cybersecurity Maturity Model Certification (CMMC) framework as the primary method for assessing, tracking, and reporting the effectiveness of its cybersecurity program. An organization-wide security maturity evaluation will be conducted annually across all 17 CMMC security domains, measuring capabilities from Level 1 (Basic Cyber Hygiene) through Level 5 (Optimized). The Chief Information Security Officer (CISO) is responsible for maintaining a rolling three-year security maturity roadmap that prioritizes improvements in high-risk and high-impact domains, including but not limited to:

- Access Control
- Incident Response
- System and Communications Protection
- Security Assessment and Monitoring

Security maturity results, identified gaps, and roadmap progress will be formally reported to executive leadership and the Board of Directors on an annual basis to ensure alignment with SnowBe’s risk appetite and business objectives.

This policy shifts SnowBe’s security program from a checklist-driven approach to a measured, accountable, and strategic cybersecurity program focused on continuous improvement.

Security Maturity Framework:

SnowBe Online will use the CMMC framework, which defines five maturity levels:

- Level 1 – Basic Cyber Hygiene:
Basic safeguards are in place and performed informally.
- Level 2 – Intermediate:
Practices are documented and partially implemented across the organization.
- Level 3 – Good Cyber Hygiene:
Security practices are fully implemented, managed, and institutionalized.
- Level 4 – Proactive:
Security practices are reviewed, measured, and proactively improved.
- Level 5 – Optimized:
Security practices are advanced, adaptive, and continuously optimized.

Each maturity level builds upon the previous level and applies across the 17 CMMC security domains.

Security Maturity Assessment Process

1. Annual Assessment
 - Conduct an annual CMMC-aligned maturity assessment across all domains.
 - Assess both technical controls and supporting processes.
2. Evidence-Based Scoring
 - Maturity scores must be supported by documented evidence such as policies, system configurations, logs, and reports.
3. Gap Identification
 - Identify gaps between current maturity levels and target maturity levels.
4. Roadmap Development
 - Update the three-year security roadmap with prioritized actions, owners, and timelines.
5. Reporting
 - Deliver a formal maturity report to leadership and the Board, including:
 - Current maturity levels
 - Improvements achieved
 - Outstanding risks
 - Planned initiatives

This policy will be reviewed:

- Annually
- After significant security incidents
- After major organizational or regulatory changes

Exceptions/Exemptions

Any deviation from this plan must be:

1. Submit deviation form to IT Director
2. Approved by the IT Director
3. Documented with compensating controls
4. Time-limited with a remediation deadline (max of 1 year)

Enforcement

Escalation structure:

1. **Verbal Warning** – first minor policy violation
2. **Written Warning** – documented repeat violations
3. **Suspension of System Access** – short-term, retraining required
4. **Job-related Discipline** – reassignment, loss of privileges
5. **Termination and Legal Action** – for severe/repeated offenses
6. **Criminal Prosecution** – if actions violate state/federal laws

Network or system removal may occur immediately if needed to protect SnowBe systems.

Version History Table

Version #	Implementation Date	Document Owner	Approved By	Description
1.0	20251221	Ethan Platt	SnowBe	Initial Maturity and Roadmap Policy

Citations

<https://its.ny.gov/secure-system-development-life-cycle-standard>